COMPTIA SECURITY+ SY0-701 | DOMAIN 2 · THREATS, VULNERABILITIES, AND MITIGATIONS (22%)

Security+ 2.2 · Common Threat Vectors

Mestre CyberSec · **Lesson 2.2 — Common Threat Vectors** (17:14) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Vetores = como o ataque chega: email/SMS/voz, imagem, arquivo, chamada, credencial default nunca trocada, software infectado, USB baiting, malvertising (anúncio malicioso), credential stuffing (reuso de senha vazada), insider, rede remota, IoT/nuvem física.

💡 Key Exam Highlights & Critical Concepts

- Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA
- Malvertising: anúncio malicioso em site legítimo
- Credential stuffing = USAR senha vazada em outros sites (vs brute force)

🎯 Exam Tips & Typical CompTIA Scenarios

- 'reuses leaked credentials across multiple sites' = credential stuffing
- 'malicious advertisement on a legitimate website' = malvertising

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.2 — Common Threat Vectors)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Credential Stuffing (N/A)

An attack where credentials (username/password pairs) previously leaked in data breaches are automatically reused across multiple unrelated sites to gain unauthorized access.

⚠ ***Exam Trap:*** *Trigger phrase 'reuses leaked credentials across multiple sites' = Credential Stuffing. Do NOT confuse with Brute Force (which guesses passwords without prior breach data) or Password Spraying (tries common passwords against many users).*

• Malvertising (N/A)

Malicious code injected into legitimate online advertising networks that redirects users to exploit kits or installs malware when the ad is displayed on trusted websites.

⚠ ***Exam Trap:*** *Trigger phrase 'malicious advertisement on a legitimate website' = Malvertising. Key distinction: the site itself is NOT compromised; only the ad content served through the ad network is malicious.*

• USB Baiting (N/A)

A physical social engineering attack where an attacker leaves infected USB drives in public locations hoping a curious user will plug them into a workstation, executing embedded malware.

⚠ ***Exam Trap:*** *Classified under the PHYSICAL threat vector category. Distinguish from supply chain attacks (USB shipped in hardware) — baiting relies on human curiosity and is intentionally placed.*

• Supply Chain Attack (N/A)

An attack that compromises a trusted third-party vendor, software update, or hardware component to distribute malware downstream to end users and organizations.

⚠ ***Exam Trap:*** *Look for hints like 'compromised software update', 'malicious code in legitimate hardware', or 'third-party vendor breach'. Differentiate from direct attacks — the victim trusts the source because it's the genuine vendor.*

• Default Credentials (N/A)

Factory-set usernames and passwords (e.g., admin/admin) that shipped unchanged on devices such as routers, IoT devices, and servers, creating immediate unauthorized access if never modified.

⚠️ ***Exam Trap:*** *On the exam, 'never changed the default password' or 'using factory credentials' = Default Credentials vulnerability. Common in IoT and network infrastructure devices.*

• Phishing (Email/SMS/Voice) (N/A)

Social engineering delivered via email (phishing), SMS (smishing), or voice calls (vishing) that tricks users into revealing credentials, clicking malicious links, or downloading malware.

⚠️ ***Exam Trap:*** *Know the trio: Email = Phishing, SMS = Smishing, Voice = Vishing. All are message-based vectors. Whaling targets executives; Spear Phishing targets specific individuals using researched info.*

• Insider Threat (N/A)

A threat originating from people within the organization — employees, contractors, or partners — who misuse legitimate access to harm systems, steal data, or leak information, whether malicious or accidental.

⚠️ ***Exam Trap:*** *Trigger phrases: 'malicious employee', 'disgruntled staff', 'negligent contractor', or 'privileged user abuse'. Distinguish from external attackers — insider already has authorized network access.*

• Unsecured Remote Access / IoT Attack Surface (N/A)

Exploitation of weakly protected remote services (RDP, SSH, VPN) and Internet-of-Things devices that lack proper hardening, patching, or network segmentation, exposing them to external attackers.

⚠️ ***Exam Trap:*** *Exam will mention 'exposed RDP', 'unpatched IoT camera', or 'open SSH port to internet'. Remember: IoT devices often ship with default credentials AND unencrypted remote access enabled.*

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A financial services company's webmail portal logs show a sudden spike in successful logins from different IP addresses. The usernames and passwords match credentials from a recent breach at a popular fitness app. Many employees used the same password for both services. Which threat vector is most likely?

A) Password spraying

B) Credential stuffing

C) Brute-force attack

D) Session hijacking

QUESTION 2 · EXAM SCENARIO

Several employees at a defense contractor find USB flash drives in the parking lot and break room. The drives are labeled 'Q4 Layoffs' and 'Confidential Bonus List.' One employee plugs a drive into a corporate workstation, and malware installs silently. Which threat vector is this?

A) Watering hole

B) Supply chain attack

C) USB baiting

D) Malvertising

QUESTION 3 · EXAM SCENARIO

Users at a marketing firm visit a legitimate news website. The site's ad network serves a malicious advertisement that redirects some browsers to an exploit kit. No user clicked the ad, but a drive-by download attempts to install malware. Which threat vector is involved?

A) Malvertising

B) Typosquatting

C) Credential stuffing

D) Insider threat

QUESTION 4 · EXAM SCENARIO

A company installs a routine update from a trusted software vendor. The update is digitally signed but contains a hidden backdoor that allows attackers to access customer data. Which threat vector is this?

A) USB baiting

B) Default credentials

C) Vishing

D) Supply chain attack

QUESTION 5 · EXAM SCENARIO

A security assessment finds that many network routers and IP cameras in a corporate office still use the manufacturer's default administrator username and password. Attackers gain access and change device settings. Which threat vector is most directly exploited?

A) Default credentials

B) Credential stuffing

C) Zero-day exploit

D) Malvertising

QUESTION 6 · EXAM SCENARIO

An accounting employee receives an email that appears to be from the CFO. The email asks the employee to open an attached 'urgent invoice' file and enable macros to view it. After doing so, malware executes. Which threat vector is this?

A) Smishing

B) Vishing

C) Phishing email with a malicious attachment

D) USB baiting

QUESTION 7 · EXAM SCENARIO

Employees receive text messages claiming their corporate VPN password will expire today. The message includes a link to a fake login page that harvests credentials. Which threat vector is this?

A) Vishing

B) Smishing

C) Phishing email

D) Credential stuffing

QUESTION 8 · EXAM SCENARIO

An attacker calls an employee and claims to be from the IT help desk. The caller says there is a problem with the employee's account and asks the employee to read the one-time password sent to their phone. The attacker then uses it to log in. Which threat vector is this?

A) Smishing

B) Phishing email

C) USB baiting

D) Vishing

QUESTION 9 · EXAM SCENARIO

A disgruntled employee with authorized access to the customer database copies thousands of records to a personal cloud storage account just before resigning. The employee's credentials were valid, and no external malware was involved. Which threat vector is this?

A) Insider threat

B) Supply chain attack

C) Malvertising

D) Unsecured remote access

QUESTION 10 · EXAM SCENARIO

A hospital has internet-connected infusion pumps that run outdated firmware and are reachable from the guest Wi-Fi network. Attackers exploit the pumps to gain a foothold and move laterally. Which threat vector is most directly exploited?

A) Supply chain attack

B) IoT attack surface

C) Credential stuffing

D) Vishing

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option B — Credential stuffing
Attackers take leaked username/password pairs from one breach and try them on other sites. This is credential stuffing. Password spraying uses a few common passwords across many accounts; brute force guesses passwords; session hijacking steals active session tokens.

Question 2: Option C — USB baiting
Leaving infected USB drives for victims to find and plug in is USB baiting. Watering hole compromises a website frequented by targets; supply chain compromises a vendor; malvertising uses malicious ads.

Question 3: Option A — Malvertising
Malvertising is malicious advertising delivered through legitimate ad networks. Typosquatting uses look-alike domains; credential stuffing uses leaked credentials; insider threat is internal.

Question 4: Option D — Supply chain attack
A supply chain attack compromises a trusted vendor or software update to deliver malware. USB baiting uses physical drives; default credentials are unchanged passwords; vishing is voice phishing.

Question 5: Option A — Default credentials
Default credentials are factory-set usernames/passwords that were never changed. Credential stuffing uses leaked credentials from other breaches; zero-day exploits unknown vulnerabilities; malvertising uses malicious ads.

Question 6: Option C — Phishing email with a malicious attachment
The attack arrives via email and uses a malicious attachment, a type of phishing. Smishing is SMS phishing; vishing is voice phishing; USB baiting uses physical drives.

Question 7: Option B — Smishing
Smishing is phishing conducted via SMS/text messages. Vishing uses voice calls; phishing email uses email; credential stuffing uses leaked credentials on other sites.

Question 8: Option D — Vishing
Vishing is voice phishing, typically a phone call that manipulates the victim into revealing sensitive information or performing an action. Smishing uses text messages; phishing email uses email; USB baiting uses physical drives.

Question 9: Option A — Insider threat
An insider threat involves a trusted individual misusing legitimate access. Supply chain attacks compromise vendors; malvertising uses ads; unsecured remote access involves external exposure.

Question 10: Option B — IoT attack surface
The IoT attack surface consists of internet-connected devices with weak security, outdated firmware, or exposed services. Supply chain compromises vendors; credential stuffing uses leaked credentials; vishing is voice phishing.